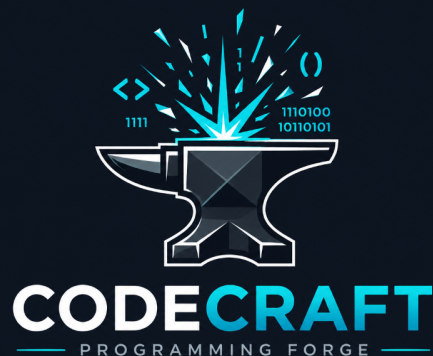




SISTEMA DE CONTROL DE DISPOSITIVOS MÓVILES FINANCIADOS

Diseño de Arquitectura Tecnológica y Seguridad de Extremo a Extremo para Venta de
Terminales a Crédito

Preparado por: CodeCraft Programming Forge

Rol: Arquitecto de Software Senior & Experto en Seguridad Móvil

Fecha: Junio 2026

Versión: 1.0.0 (Propuesta Técnica)

1. Introducción y Metodología de Trabajo

Este documento técnico describe detalladamente la arquitectura propuesta para mitigar el riesgo de impago en la comercialización de teléfonos móviles financiados. El enfoque principal reside en el uso de herramientas empresariales y APIs nativas oficiales proporcionadas por Google, Apple y fabricantes de hardware como Samsung. Esto garantiza que las restricciones de bloqueo no puedan ser evadidas mediante técnicas ordinarias y que la aplicación cumpla plenamente con los términos de servicio y políticas de seguridad vigentes.

El desarrollo del proyecto se ejecutará en cuatro fases clave bajo una metodología ágil (Scrum):

- **Fase 1: Diseño e Infraestructura Base:** Configuración del entorno de base de datos, APIs de comunicación segura, registro en Apple Business Manager y consolas de Android Enterprise.
- **Fase 2: Desarrollo del Agente de Control Móvil:** Implementación de los módulos de restricciones en los dispositivos usando las APIs oficiales de MDM y Android Enterprise.
- **Fase 3: Panel de Control y Automatizaciones:** Desarrollo de la interfaz administrativa web e integración automatizada con pasarelas de pago para procesamiento inmediato de comandos de desbloqueo.
- **Fase 4: Auditoría de Seguridad y Despliegue:** Pruebas de penetración, pruebas de bypass de Root/Jailbreak, endurecimiento de código (ofuscación) y lanzamiento a producción.

2. Arquitectura del Cliente Móvil

Debido al aislamiento de aplicaciones (sandboxing) en sistemas operativos modernos, las aplicaciones estándar descargadas de las tiendas no tienen permisos para realizar bloqueos de pantalla o prevenir la desinstalación. Por ende, se estructuran dos soluciones específicas para cada plataforma:

Plataforma Android

Para dispositivos Android, se implementa el modo **Device Owner** (Propietario del Dispositivo) a través de la infraestructura de Android Enterprise. Durante el primer encendido del dispositivo, se realiza el aprovisionamiento mediante escaneo de código QR o enrolamiento automático (Zero-Touch Enrollment). Esto le otorga a la app privilegios a nivel de sistema para:

- Impedir la desinstalación de la aplicación de control.
- Deshabilitar el restablecimiento de valores de fábrica (Factory Reset).
- Restringir la instalación de aplicaciones no autorizadas o el acceso a la depuración USB (ADB).
- Para dispositivos Samsung, se integrará adicionalmente el SDK de **Knox Guard**, el cual añade protección persistente vinculada al hardware y al número de serie del dispositivo, reactivando los bloqueos inmediatamente si el usuario realiza un formateo de bajo nivel.

Plataforma iOS (Apple)

En iOS no se despliega un agente autónomo de bloqueo. En su lugar, el dispositivo debe ser enrolado en modo **Supervisado** vinculándolo a una cuenta corporativa de **Apple Business Manager (ABM)**. Un servidor MDM (Mobile Device Management) propio se encarga de enviar políticas restrictivas directamente al kernel del sistema operativo mediante perfiles de configuración no removibles. Cuando ocurre un impago, el backend envía un comando MDM para colocar el terminal en modo de aplicación única (Kiosk Mode), impidiendo su uso general.

3. Seguridad de Red y API de Comunicaciones

La integridad de los comandos de bloqueo y desbloqueo es crítica. Para evitar que usuarios avanzados intercepten las comunicaciones o emulen servidores de validación falsos, se configuran las siguientes medidas:

- **Cifrado de Tránsito (TLS 1.3):** Toda la comunicación viaja exclusivamente por HTTPS utilizando TLS 1.3 con suites de cifrado seguras.
- **Certificate Pinning:** Se embeben los hashes de la clave pública del certificado SSL en el binario de la aplicación móvil. Si el usuario intenta usar un proxy para analizar o modificar las peticiones, la app rechazará la conexión de inmediato.
- **Firma Asimétrica de Comandos:** Los comandos críticos de bloqueo y desbloqueo son firmados en el backend usando una clave privada mediante el algoritmo criptográfico **ECDSA (curva P-256)**. La aplicación cliente valida localmente que la firma del comando corresponda a la clave pública autorizada antes de ejecutar la acción.
- **Arquitectura de Comunicación Híbrida:** Se envían alertas prioritarias (push silenciosos) a través de Firebase Cloud Messaging (FCM) y Apple Push Notification service (APNs). El dispositivo recibe la notificación y realiza una consulta síncrona a la API central para descargar y procesar las órdenes firmadas.

4. Resumen de Controles de Seguridad

La siguiente tabla resume los riesgos operativos identificados y las salvaguardas tecnológicas planteadas en el diseño:

Riesgo / Amenaza	Salvaguarda Tecnológica	Mecanismo de Control
Desinstalación de la App	Device Owner / MDM Profile	Restricciones nativas del SO impiden la remoción sin credenciales de administrador.
Formateo Físico (Factory Reset)	Knox Guard / ABM Enrollment / Políticas de Seguridad	Deshabilitación de la opción en menú. Reactivación automática del bloqueo al reconectar a internet en el arranque.
Interceptación de Tráfico (MITM)	TLS 1.3 + Certificate Pinning	Validación estricta de certificados TLS. La app no confía en certificados locales de usuario.
Suplantación de Comandos	Firma Criptográfica Asimétrica (ECDSA)	Cada orden debe estar firmada por el servidor. La app rechaza payloads sin firma válida.
Ingeniería Inversa del Código	Ofuscación (R8/DexGuard/SwiftShield)	Dificulta el análisis estático del binario, el descifrado de cadenas y el flujo de llamadas.

Ejecución en Emuladores / Dispositivos Modificados	Play Integrity / App Attest / Detección de Root	Evaluación en tiempo de ejecución del estado del hardware. Denegación de servicio en terminales rooteados.
--	---	--

5. Propuesta Económica e Implementación

Para el desarrollo y puesta en marcha del sistema integral, se plantea un presupuesto optimizado basado en el uso de herramientas de código abierto (como MicroMDM para iOS) y configuraciones nativas de bajo costo, garantizando un precio altamente competitivo en el mercado colombiano sin comprometer la seguridad del aplicativo.

Comparativa de Valor y Referencia del Mercado: Un desarrollo a la medida tradicional de esta complejidad técnica (MDM corporativo, seguridad criptográfica, integraciones de pago y apps nativas) suele cotizarse en la industria de software por un valor de **\$ 28,000,000 COP**. No obstante, gracias al uso de infraestructura optimizada autohospedada, podemos presentar una oferta comercial muy agresiva y económica.

Modelo de Solución	Valor de Referencia de Mercado	Nuestra Propuesta Optimizada
Desarrollo a la Medida Corporativo (Estándar)	\$ 28,000,000 COP	\$ 3,800,000 COP

Presupuesto de Desarrollo (Pago Único)

El desarrollo del software se dividirá en entregables por fases asociados a los siguientes hitos de pago sobre nuestra tarifa optimizada de **\$ 3,800,000 COP** (pago único, propiedad absoluta del código sin mensualidades por desarrollo):

Fase de Desarrollo	Entregables Clave	Valor (COP)
Fase 1: Infraestructura y Enrolamiento	Registro ABM/Google Enterprise, diseño de BD, API Gateway y certificados SSL/APNs.	\$ 600,000
Fase 2: Agente Móvil y Políticas	App Android Device Owner, integración Knox Guard y perfiles de restricción iOS.	\$ 1,500,000
Fase 3: Backend, Admin Web y Pagos	Panel Web administrativo, API de comunicación cifrada e integración de pasarelas de pago.	\$ 1,200,000
Fase 4: Auditoría y Despliegue	Pruebas de bypass de root/formateo, endurecimiento, ofuscación y paso a producción.	\$ 500,000
VALOR TOTAL DE DESARROLLO	Software llave en mano, propiedad del código fuente y 6 meses de garantía.	\$ 3,800,000 COP

Costos de Operación y Licencias de Terceros (No incluidos)

Para el funcionamiento continuo del sistema, el cliente final debe considerar los siguientes costos recurrentes que se pagan directamente a los proveedores de servicios (optimizados para iniciar con la infraestructura mínima y más económica):

Concepto	Proveedor / Frecuencia	Costo Estimado (COP)
Cuenta Apple Developer Program	Apple / Pago Anual (Obligatorio para iOS)	~ \$ 400,000 / año (USD 99)
Cuenta Google Play Console	Google / Pago Único (Obligatorio para Android)	~ \$ 100,000 (una sola vez) (USD 25)
Servidor Web, Base de Datos y MDM (Fase Inicial)	DigitalOcean / Hetzner / Mensual (Servidor básico)	\$ 30,000 a \$ 80,000 / mes (USD 8-20)
Licencias Samsung Knox Guard	Samsung / Pago Anual por Celular (Opcional)	~ \$ 4,000 a \$ 8,000 / año por dispositivo (USD 1-2)
Servidor MDM (MicroMDM)	Open-Source / Mensual (Sin costo de licencias)	\$ 0 COP (Alojado en el mismo servidor web)

Nota de Ahorro en Hosting: Durante las fases de desarrollo, pruebas y hasta los primeros 500 dispositivos registrados, utilizaremos una configuración simplificada en un único servidor VPS económico (como Hetzner o DigitalOcean) con costos iniciales de apenas **\$30.000 COP al mes**. La infraestructura es elástica y solo requerirá aumentar de tamaño si el volumen de dispositivos supera los límites de procesamiento, garantizando la máxima economía para el inicio del proyecto.